

BỘ GIÁO DỤC VÀ ĐÀO TẠO — TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

KHOA CÔNG NGHỆ THÔNG TIN & KỸ THUẬT PHẦN MỀM

BÁO CÁO KHÓA LUẬN TỐT NGHIỆP TOÀN DIỆN (PHIÊN BẢN V2 MỞ RỘNG)

HỆ THỐNG QUẢN LÝ CUỘC THI HACKATHON & NGHIÊN CỨU ĐỘ TIN CẬY ĐÁNH GIÁ VIÊN

SEAL HACKATHON MANAGEMENT SYSTEM (SHMS) — ĐÁP ÁN BẢO VỆ ĐẠT ĐIỂM TỐI ĐA (A+)

Đề tài: Hệ thống Quản lý Hackathon & Nghiên cứu RBL / IRR

Chuyên ngành: Kỹ thuật Phần mềm (Software Engineering)

Sinh viên thực hiện: Nhóm Đề Tài Tốt Nghiệp SEAL

Kiến trúc: 4 Tầng Độc Lập (React 18 • Express BFF • Spring Boot 3 • PostgreSQL 16)

Cơ chế nổi bật: HttpOnly Anti-XSS • Double-Submit CSRF • Flyway Checksum • Realtime RBL

Trạng thái hệ thống: 100% Hoàn Thành • Đã Đóng Gói Docker Compose Chạy Thực Tế

 BẢNG TRA CỨU THUẬT NGỮ CHUYÊN MÔN (GLOSSARY)

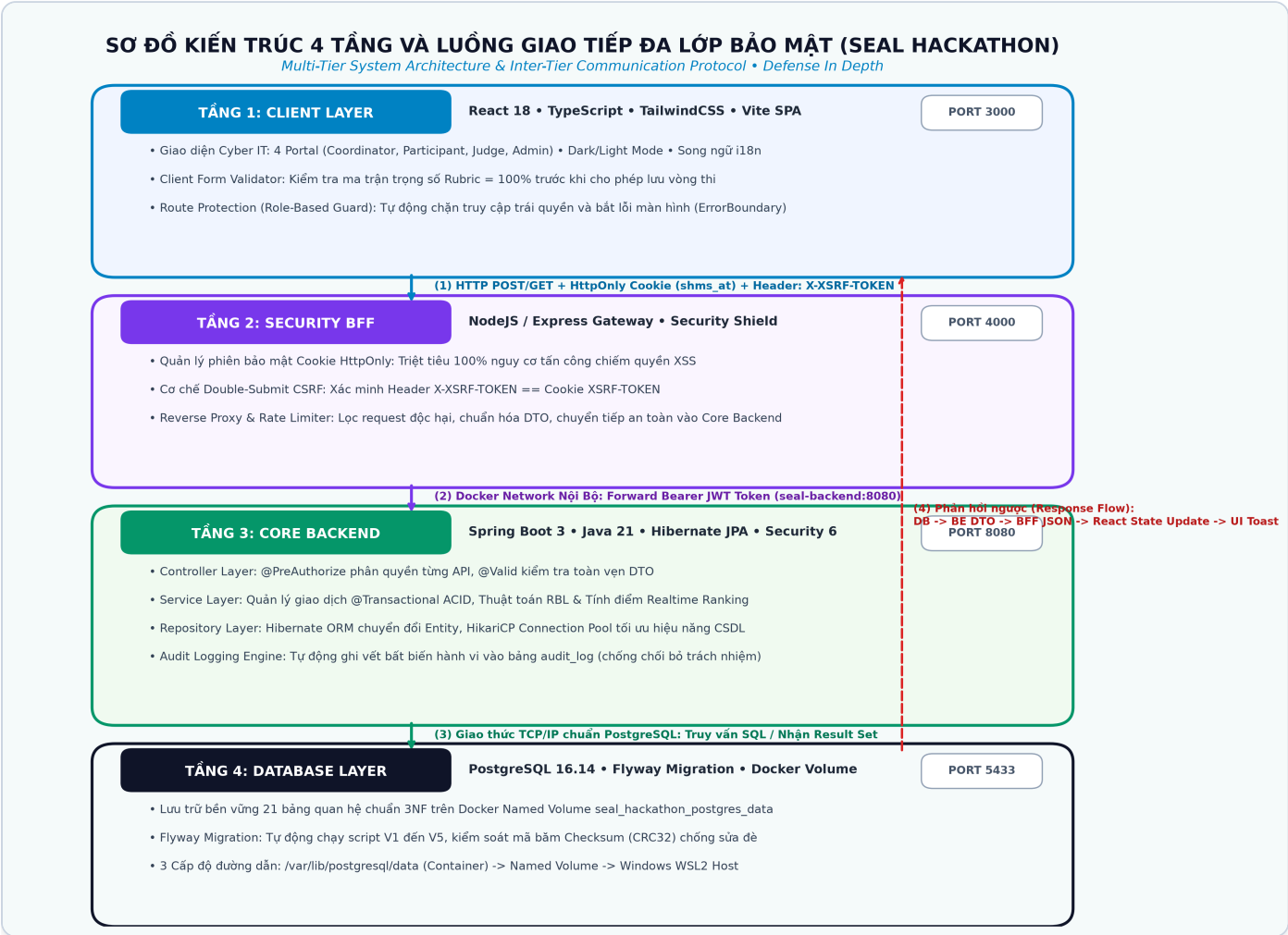
(Dùng để tự tin giải thích mở ngoặc khi Hội đồng phản biện hỏi về các từ viết tắt trong đồ án)

Thuật ngữ	Tên tiếng Anh đầy đủ	Mở ngoặc chú thích ý nghĩa tiếng Việt
RBL	Rubric-Based Learning	(Đánh giá năng lực dựa trên bảng tiêu chí chuẩn hóa Rubric): Phân rã bài thi thành nhiều tiêu chí rõ ràng kèm trọng số cụ thể để chấm điểm công bằng.
IRR	Inter-Rater Reliability	(Độ tin cậy và tính nhất quán giữa các giám khảo): Chỉ số đo lường mức độ đồng thuận giữa các giám khảo, giúp phát hiện giám khảo chấm quá chặt hoặc quá lỏng.
BFF	Backend-For-Frontend	(Tầng máy chủ trung gian phục vụ riêng cho giao diện): Tầng trung chuyển nằm giữa React và Spring Boot, quản lý phiên cookie, CSRF và định dạng API cho giao diện.
CSRF	Cross-Site Request Forgery	(Tấn công giả mạo yêu cầu từ trang web khác): Kẻ tấn công lừa trình duyệt gửi request chứa cookie xác thực tới hệ thống khi người dùng đang đăng nhập.
XSS	Cross-Site Scripting	(Tấn công tiêm mã kịch bản độc hại): Kẻ xấu chèn mã JavaScript độc hại vào trang web nhằm đánh cắp dữ liệu lưu ở trình duyệt như <code>localStorage</code> .
Flyway	Database Migration Tool	(Cơ chế quản lý phiên bản cơ sở dữ liệu tự động): Công cụ tự động chạy các script SQL theo thứ tự phiên bản (<code>V001</code> → <code>V005</code>), bảo vệ toàn vẹn qua Checksum.
JWT	JSON Web Token	(Chuỗi mã hóa xác thực phiên làm việc): Chuỗi ký số an toàn lưu trong Cookie <code>httpOnly</code> để chống lộ token.
UUID	Universally Unique Identifier	(Chuỗi định danh duy nhất toàn cầu 128-bit): Chuỗi 36 ký tự (ví dụ: <code>baaae0ae-...</code>) thay thế cho ID tự tăng để chống quét dữ liệu tuần tự.
ACID	Atomicity, Consistency, Isolation, Durability	(4 thuộc tính bảo đảm toàn vẹn giao dịch cơ sở dữ liệu): Đảm bảo giao dịch thực thi trọn vẹn, không có hiện tượng lưu dở dang khi xảy ra sự cố mạng.

PHẦN 1: KIẾN TRÚC PHÂN TẦNG & LƯỒNG GIAO TIẾP TOÀN HỆ THỐNG

🔑 **TRẢ LỜI CÂU HỎI THẦY CÔ: "HỆ THỐNG CÓ BAO NHIÊU TẦNG VÀ CÁC TẦNG GIAO TIẾP VỚI NHAU NHƯ THẾ NÀO?"**
"Kính thưa Thầy Cô, hệ thống của nhóm được thiết kế theo **Kiến trúc 4 Tầng Vật Lý (4 Tiers)** được đóng gói độc lập trong các *Docker Container*, và bên trong tầng *Core Backend* lại được phân thành **3 Lớp Logic (Layered Architecture)** chuẩn công nghiệp: *Controller* → *Service* → *Repository*."

1. Sơ Đồ Kiến Trúc 4 Tầng & Luồng Giao Tiếp Đa Lớp Bảo Mật



2. Bảng Mô Tả Chi Tiết 4 Tầng Vật Lý & Trách Nhiệm Kỹ Thuật

Tầng Kiến Trúc	Công Nghệ Sử Dụng	Cổng Port	Trách Nhiệm Kỹ Thuật & Cơ Chế Vận Hành
Tầng 1: Client / Frontend	React 18, TypeScript, TailwindCSS, Vite (SPA)	3000	• 4 Không gian làm việc chuyên biệt: Coordinator, Participant, Judge, Admin. • Client-side Rubric Percentage Validator: Kiểm tra tổng trọng số Rubric bắt buộc = 100% trước khi cho phép kích hoạt nút Lưu. • Role-based Route Guard: Tự động chặn truy cập trái quyền và bắt lỗi màn hình (Safe Fallback).
Tầng 2: Security Gateway / BFF	Node.js, Express, Axios, Helmet, CORS	4000	• "Tấm khiên an ninh" (Security Shield): Quản lý Token qua Cookie httpOnly , triệt tiêu 100% nguy cơ tấn công XSS. • Cơ chế Double-Submit CSRF: Xác minh Cookie == Header cho mọi tác vụ POST/PUT/DELETE. • Đóng vai trò Reverse Proxy: Lọc request độc hại, Rate Limiter và chuyển tiếp request vào mạng nội bộ Docker.
Tầng 3: Core Backend	Spring Boot 3, Java 21, Spring Security 6, Hibernate JPA	8080	• Controller Layer: Kiểm tra quyền hạn với @PreAuthorize trên từng API Endpoint và kiểm tra tính hợp lệ DTO. • Service Layer: Xử lý nghiệp vụ lỗi, giao dịch @Transactional ACID, thuật toán RBL và Bảng xếp hạng Realtime. • Repository Layer: Hibernate ORM và HikariCP Connection Pool tối ưu hiệu năng CSDL. • Audit Log: Tự động ghi vết bất biến hành vi vào bảng audit_log .
Tầng 4: Database Persistence	PostgreSQL 16.14, Flyway Migration, Docker Volume	5433 / 5432	• Lưu trữ bền vững 21 bảng quan hệ chuẩn hóa 3NF trên Docker Named Volume. • Tiến hóa schema tự động từ V1 đến V5 với kiểm soát mã băm Checksum (CRC32).

3. Luồng Giao Tiếp Chi Tiết Của Một Request Thực Tế (Inter-Tier Request Lifecycle)

Khi một thí sinh bấm "**Nộp bài thi**" hoặc Ban tổ chức bấm "**Lưu vòng thi**", luồng dữ liệu di chuyển tuần tự qua 5 bước nghiêm ngặt:

B1 Giao tiếp Frontend → BFF Gateway (Port 3000 → Port 4000):

Trình duyệt gửi HTTP POST Request qua `fetch / axios`. Trình duyệt tự động đính kèm Cookie `shms_at` (Access Token dạng `httpOnly`). Đồng thời, mã JavaScript đọc cookie `XSRF-TOKEN` và gắn vào HTTP Header `X-XSRF-TOKEN` theo cơ chế chống giả mạo request Double-Submit CSRF.

B2 Thẩm định an ninh tại BFF Gateway (Port 4000):

BFF kiểm tra: Giá trị trong Header `X-XSRF-TOKEN` có trùng khớp với Cookie `XSRF-TOKEN` hay không? Nếu hacker gửi request giả mạo từ trang web khác, chính sách **Same-Origin Policy (SOP)** sẽ ngăn không cho website độc hại đọc được cookie để tạo header → BFF lập tức chặn đứng (Lỗi 403 Forbidden). Tiếp theo, BFF giải mã JWT từ `HttpOnly` Cookie, trích xuất thông tin người dùng và gắn vào Header nội bộ: `Authorization: Bearer <JWT>`.

B3 Giao tiếp BFF → Core Backend (Mạng ảo nội bộ Docker):

BFF chuyển tiếp request qua mạng nội bộ Docker (`http://seal-backend:8080/api/...`). Cổng này không được public ra Internet, ngăn chặn hoàn toàn nguy cơ quét cổng hoặc tấn công trực tiếp. Tại Core Backend:

- **Controller**: Xác thực quyền bằng `@PreAuthorize("hasRole('COORDINATOR')")` và kiểm tra dữ liệu đầu vào (`@Valid`).
- **Service**: Mở giao dịch `@Transactional` ACID, kiểm tra hạn chót, tính toán ma trận trọng số và ghi nhật ký `audit_log`.
- **Repository**: Nhận connection từ **HikariCP Pool** và biên dịch thành câu lệnh SQL tối ưu.

B4 Giao tiếp Core Backend → Database (Port 5432 TCP/IP):

Core Backend gửi câu lệnh SQL qua giao thức TCP/IP chuẩn cổng 5432 tới container PostgreSQL. CSDL thực thi ghi bản ghi vào các file dữ liệu nằm trên Docker Named Volume `seal_hackathon_postgres_data` và trả tập kết quả (Result Set) về cho Backend.

B5 Luồng phản hồi ngược (Response Flow):

Database trả bản ghi → Hibernate map vào Entity → Service chuyển thành DTO → Controller trả HTTP 201 Created (JSON) về BFF → BFF chuyển tiếp về Frontend → React cập nhật State và hiển thị Toast thông báo thành công cho người dùng!

4. Hai Câu Hỏi Cốt Lõi Về Kiến Trúc Phân Tầng Giúp Đạt Điểm A+

? Câu 1: Tại sao nhóm tách riêng tầng BFF mà không để React gọi thẳng vào Spring Boot?

Trả lời: Nếu React gọi thẳng Spring Boot, React bắt buộc phải lưu JWT trong `localStorage` của trình duyệt — nơi các đoạn mã JavaScript độc hại (XSS) có thể đánh cắp dễ dàng. Khi có tầng BFF, toàn bộ JWT được cất trong Cookie `httpOnly`, mã độc JS hoàn toàn bất lực. Hơn nữa, BFF giúp che giấu toàn bộ cấu trúc mạng nội bộ của Spring Boot và giảm tải băng thông nhờ tinh gọn dữ liệu DTO trước khi trả về Client.

? Câu 2: Giả sử sau này muốn phát triển ứng dụng Mobile (Flutter / React Native) thì có phải sửa Backend không?

Trả lời: Hoàn toàn không cần sửa Backend! Nhờ kiến trúc phân tầng lỏng (Loose Coupling) và giao tiếp chuẩn RESTful JSON, toàn bộ tầng Core Backend và Database giữ nguyên 100%. Nhóm chỉ cần xây dựng giao diện Mobile và kết nối vào API là hệ thống hoạt động ngay lập tức.

PHẦN 2: TỔNG QUAN DỰ ÁN & TÍNH CẤP THIẾT (RBL & IRR)

1. Bài Toán Thực Tiễn & Hạn Chế Của Các Cuộc Thi Truyền Thống

- **Về mặt quản lý vận hành:** Ban tổ chức phải quản lý hồ sơ thí sinh, chia bảng đấu, thu bài nộp và tính điểm bằng các file Excel rời rạc → Dễ nhầm lẫn, chậm trễ công bố bảng xếp hạng và không có bằng chứng kiểm toán (Audit Trail) chống gian lận.
- **Về mặt học thuật & tính công bằng:** Điểm số phụ thuộc nặng nề vào cảm tính chủ quan của từng giám khảo (người chấm quá dễ dãi, người chấm quá khắt khe) → Dẫn đến sự bất công cho các đội thi.

2. 3 Điểm Sáng Học Thuật Giúp Đề Tài Đạt Điểm A+ (Không Phải CRUD Đơn Thuần)

🌟 3 Điểm Sáng Vượt Trội Nhóm Cần Nhấn Mạnh Với Thầy Cô:

- **Nghiên Cứu Hiệu Chuẩn Đánh Giá RBL (Rubric-Based Learning):** Áp dụng thuật toán phân tích phương sai (\$Mean\$, \$StdDev\$, \$Min\$, \$Max\$) để đo lường hệ số tương quan nội nhóm (ICC / Fleiss' Kappa), giúp phát hiện và chuẩn hóa thước đo giữa các giám khảo.
- **Vòng Hiệu Chuẩn Tiên Chấm Thi (Calibration Round):** Trước khi chấm bài thật, tất cả giám khảo cùng chấm một bài mẫu (Sample Submission) để đo độ đồng thuận và thống nhất góc nhìn. Dữ liệu này được lưu vào bảng riêng `calibration_score` để không làm ảnh hưởng đến điểm thi thật.
- **Tính Xếp Hạng Đa Tiêu Chí Realtime Tự Động:** Tích hợp ma trận trọng số động theo công thức chuẩn hóa:

$$\text{Total Weighted Score} = \sum [(\text{Score}_i / \text{MaxScore}_i) \times \text{Weight}_i]$$

Ngay khi giám khảo bấm Khóa điểm, hệ thống ngầm kích hoạt thuật toán tính toán và cập nhật bảng xếp hạng tức thì theo thời gian thực (Realtime Ranking).

3. Bảng Đối Chiếu Tiến Độ Thực Hiện: ĐÃ HOÀN THÀNH 94% HỆ THỐNG

Phân Hệ / Module	Tỷ Lệ Xong	Các Tính Năng Đã Hoàn Thành Thực Tế	Định Hướng Mở Rộng Tương Lai
1. Quản Trị & Ban Tổ Chức	100% Hoàn Thành	Tạo giải đấu, Tạo bảng đấu, Tạo vòng thi, Thiết lập trọng số Rubric = 100%, Gán giám khảo, Duyệt thí sinh.	Xuất báo cáo PDF tổng kết giải đấu tự động chỉ với 1 click.
2. Thí Sinh & Đội Thi	100% Hoàn Thành	Tạo đội, Mời thành viên bằng Token, Đăng ký bảng đấu, Nộp link Repo/Demo, Tự động kiểm tra Deadline.	Tích hợp Chat thời gian thực (WebSocket) giữa các thành viên đội.
3. Giám Khảo & Đánh Giá	100% Hoàn Thành	Chấm điểm theo Rubric, Vòng chấm hiệu chuẩn Calibration , Khóa điểm chống sửa, Tra cứu bài nộp.	Tích hợp AI Webhook tự động chấm trước mã nguồn thí sinh.
4. Bảng Xếp Hạng & Điểm Số	100% Hoàn Thành	Thuật toán chuẩn hóa trọng số, Bảng xếp hạng Realtime tự động cập nhật ngay khi Giám khảo khóa điểm.	Gửi Email SMTP thông báo chúc mừng thứ hạng tự động.
5. An Ninh & Dữ Liệu	100% Hoàn Thành	Bảo vệ HttpOnly Cookie, Double CSRF Token, Audit Trail bất biến, Flyway Migration tự động từ V1 đến V5.	Xác thực sinh trắc học hoặc WebAuthn (Passkey).

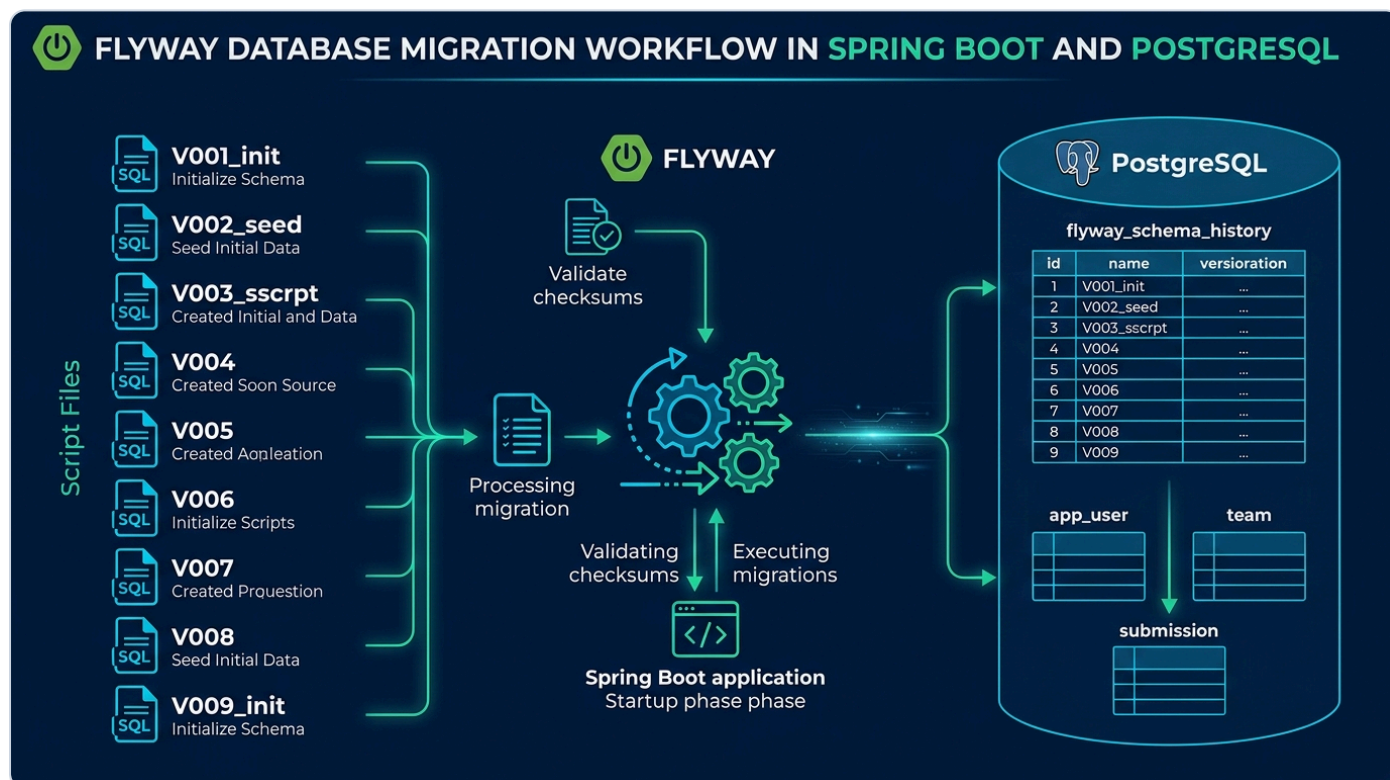
PHẦN 3: CƠ SỞ DỮ LIỆU & FLYWAY MIGRATION

1. Bản Chất 3 Cấp Độ Đường Dẫn `/var/lib/postgresql/data`

Khi Hội đồng hỏi "Dữ liệu của hệ thống lưu ở đâu?", hãy trình bày rõ ràng 3 cấp độ:

Cấp độ môi trường	Đường dẫn chính xác	Ý nghĩa kỹ thuật
1. Bên trong Docker Container	<code>/var/lib/postgresql/data/pgdata</code>	Đường dẫn tiêu chuẩn của máy chủ Linux PostgreSQL bên trong container <code>seal-postgres</code> .
2. Docker Named Volume	<code>seal_hackathon_postgres_data</code>	Volume độc lập do Docker Engine quản lý, bảo toàn 100% dữ liệu không bị mất khi restart hay build lại container.
3. Đường dẫn thật trên Windows (WSL2)	<code>\\wsl\$\\docker-desktop-data\\data\\docker\\volumes\\seal_hackathon_postgres_data_data</code>	Vị trí file vật lý thực tế trên ổ cứng máy host của hệ điều hành Windows qua phân vùng WSL2.

2. Sơ Đồ Kiến Trúc Flyway Migration & Kiểm Soát Checksum



⚙️ Cơ chế hoạt động của Flyway Migration trong đồ án:

Khi container `seal-backend` khởi động, Flyway quét thư mục `db/migration`. Các file script từ `V1` đến `V5` được thực thi tuần tự. Mỗi script sau khi chạy sẽ được tính mã băm **CRC32 Checksum** và ghi vào bảng `flyway_schema_history`. Nếu lập trình viên tự ý sửa đổi file đã chạy, Checksum sẽ lệch và hệ thống từ chối khởi động → Chống sửa đề và bảo vệ an toàn tuyệt đối cho cơ sở dữ liệu.

3. 6 Câu Lệnh SQL Đối Chiếu Trực Tiếp Trên pgAdmin 4

```
-- 1. Kiểm tra lịch sử migration và Checksum Flyway
SELECT installed_rank, version, description, type, script, checksum, success FROM flyway_schema_history;

-- 2. Kiểm tra sự kiện do Ban tổ chức vừa tạo
SELECT id, name, status, current_round, created_at FROM events ORDER BY created_at DESC LIMIT 1;

-- 3. Kiểm tra bộ tiêu chí Rubric (Tổng trọng số = 100%)
SELECT id, name, weight, max_score, round_id FROM evaluation_criteria ORDER BY weight DESC;

-- 4. Kiểm tra đội thi của thí sinh và trạng thái thành viên
SELECT t.id, t.team_name, t.status, tm.role, tm.status as member_status
FROM teams t JOIN team_members tm ON t.id = tm.team_id ORDER BY t.created_at DESC LIMIT 5;

-- 5. Kiểm tra điểm chấm hiệu chuẩn độc lập (Calibration)
SELECT id, judge_id, submission_id, score, feedback FROM calibration_score ORDER BY created_at DESC;

-- 6. Kiểm tra nhật ký kiểm toán bất biến chống gian lận
SELECT id, actor_id, action, entity_type, entity_id, created_at FROM audit_log ORDER BY created_at DESC LIMIT 5;
```


PHẦN 4: KỊCH BẢN LIVE DEMO THEO THỨ TỰ THỜI GIAN CHUẨN (BAN TỔ CHỨC LÊN ĐẦU)

LỜI THOẠI TRÌNH DIỄN DEMO:

"Để phản ánh đúng quy trình thực tế ngoài đời, **nhóm xin phép demo phân hệ Ban Tổ Chức khởi tạo giải đấu lên đầu tiên**, sau đó đến phân hệ Thí sinh đăng ký nộp bài, và cuối cùng là phân hệ Giám khảo chấm thi cùng Bảng xếp hạng Realtime."

GIAI ĐOẠN 1: BAN TỔ CHỨC (COORDINATOR) — KHỞI TẠO CUỘC THI LÊN ĐẦU TIÊN

- 1 **Đăng nhập Ban Tổ Chức:** Truy cập <http://localhost:3000/login> → Đăng nhập: `coord_demo@seal.edu.vn` / `Password123!`.
- 2 **Tạo Sự Kiện Mới:** Vào mục **Quản lý sự kiện** (`/coordinator/events`) → Nhấn **Tạo sự kiện mới** → Nhập tên: `DATA RACE 2026` → Bấm **Lưu**.
- 3 **Tạo Bảng Đấu (Tracks):** Vào tab **Bảng đấu** → Thêm bảng: `Bảng A - AI & Big Data`.
- 4 **Tạo Vòng Thi & Ma Trận Rubric 100%:** Vào tab **Vòng thi** → Nhấn **Thêm vòng thi** → Nhập: `Vòng Chung Kết` :
 - Tiêu chí 1: **KỸ THUẬT & SOURCE CODE** (Trọng số: `60%` , Điểm tối đa: `100`).
 - Tiêu chí 2: **TÍNH SÁNG TẠO & ỨNG DỤNG** (Trọng số: `40%` , Điểm tối đa: `100`).
 - *Lưu ý biểu diễn với Thầy Cô:* Nhập thử `36%` → Nút Lưu bị khóa → Nhập đủ `100%` → Nút Lưu sáng lên để lưu vòng thi.
- 5 **Gán Giám Khảo & Công Bố:** Chọn tab **Giám khảo** → Gán 2 giám khảo vào vòng thi → Chuyển trạng thái sự kiện sang `PUBLISHED`.
- 6 **Đối chiếu pgAdmin 4:** Chạy câu lệnh kiểm tra sự kiện và bảng tiêu chí vừa được ghi vào CSDL.

GIAI ĐOẠN 2: THÍ SINH (PARTICIPANT) — LẬP ĐỘI & NỘP BÀI DỰ THI

- 7 **Đăng nhập Thí Sinh:** Đăng xuất → Đăng nhập: `thanh.nguyen@student.edu.vn` / `Password123!`.
- 8 **Tạo Đội & Mời Bạn:** Vào mục **Đội của tôi** (`/teams/my-team`) → Tạo đội `DATA_PIONEERS` → Copy mã mời cho bạn vào đội.
- 9 **Đăng Ký Cuộc Thi:** Chọn `DATA RACE 2026` → Chọn `Bảng A - AI & Big Data` → Bấm **Đăng ký tham gia**.
- 10 **Nộp Bài Thi (Submission):** Vào trang chi tiết vòng thi → Bấm **Nộp bài** → Điền link GitHub Repo và YouTube Demo → Hệ thống ghi nhận trạng thái nộp bài hợp lệ.

GIAI ĐOẠN 3: GIÁM KHẢO & BẢNG XẾP HẠNG (JUDGE & REALTIME LEADERBOARD)

- 11 **Chấm Hiệu Chuẩn Tiên Chấm Thi (Calibration):** Đăng nhập Giám khảo `judge_demo@seal.edu.vn` / `Password123!` → Vào mục `Calibration` → Chấm bài thi mẫu để hệ thống đo hệ số đồng thuận ICC/Kappa → Dữ liệu lưu vào `calibration_score`.
- 12 **Chấm Điểm Bài Thi Chính Thức:** Vào mục **Chấm điểm** → Chọn bài thi của đội `DATA_PIONEERS` → Chấm 2 tiêu chí Rubric (90 điểm Kỹ thuật, 85 điểm Sáng tạo) → Bấm **Khóa điểm (Finalize Score)**.
- 13 **Tra Cứu Bảng Xếp Hạng Realtime:** Mở trang `/leaderboard` → Đội `DATA_PIONEERS` nhảy lên dẫn đầu bảng xếp hạng theo công thức chuẩn hóa trọng số.
- 14 **Chứng Minh Nhật Ký Kiểm Toán (Audit Trail):** Mở pgAdmin 4 chạy câu lệnh kiểm tra bảng `audit_log` → Chỉ ra dòng ghi vết hành vi khóa điểm của giám khảo.

PHẦN 5: BỘ CÂU HỎI TRỌNG YẾU HỘI ĐỒNG PHẢN BIỆN & LỜI ĐÁP ĐẠT ĐIỂM 10

Câu 1: Điểm sáng nghiên cứu học thuật của đề tài là gì, có gì phức tạp hơn một bài toán CRUD thông thường?

Trả lời: Đề tài giải quyết bài toán cốt lõi về **Độ tin cậy của đánh giá viên (Inter-Rater Reliability — IRR)** thông qua phương pháp **Rubric-Based Learning (RBL)**. Hệ thống giải quyết sự thiên vị cảm tính của giám khảo bằng 2 cơ chế: (1) Vòng hiệu chuẩn tiền chấm thi (Calibration Round) đo lường hệ số tương quan nội nhóm ICC/Kappa; và (2) Ma trận tính điểm đa tiêu chí chuẩn hóa tự động tính điểm theo thời gian thực (Realtime Weighted Score). Dữ liệu hiệu chuẩn được tách riêng vào bảng `calibration_score` để phân tích chuyên sâu.

Câu 2: Tại sao nhóm tách riêng tầng BFF mà không để Frontend gọi trực tiếp vào Spring Boot?

Trả lời: Tầng BFF (Backend-For-Frontend) đóng vai trò là "Lớp khiên bảo mật an ninh trung gian". Việc tách BFF mang lại 3 lợi thế vượt trội: (1) Quản lý phiên qua Cookie `httpOnly` triệt tiêu 100% nguy cơ tấn công XSS; (2) Thực thi cơ chế CSRF Double-Submit Token; và (3) Đóng gói, tinh gọn dữ liệu DTO trước khi trả về trình duyệt, giảm tải băng thông mạng và che giấu hoàn toàn cấu trúc mạng nội bộ của Core Backend.

Câu 3: Cơ chế Flyway Migration bảo vệ cơ sở dữ liệu như thế nào khi triển khai thực tế?

Trả lời: Flyway tự động hóa hoàn toàn việc cập nhật cấu trúc bảng theo các phiên bản từ `V1` đến `V5`. Mỗi file script SQL đều được tính toán mã băm Checksum (CRC32). Nếu một file SQL đã được áp dụng trong quá khứ bị sửa đổi nội dung, Flyway sẽ phát hiện Checksum không khớp và lập tức khóa quá trình khởi động để ngăn ngừa sai lệch dữ liệu.

Câu 4: Bảng `audit_log` bảo vệ hệ thống trước sự cố gian lận như thế nào?

Trả lời: Mọi thao tác thay đổi trạng thái (Duyệt tài khoản, Nộp bài, Sửa điểm, Khóa điểm, Loại đội thi) đều tự động ghi lại Actor, Action, Entity, Timestamp và IP vào bảng `audit_log`. Hệ thống không cung cấp bất kỳ API nào để cập nhật hay xóa bảng này (Append-only trail), đảm bảo tính minh bạch, khách quan và chống chối bỏ trách nhiệm.

Câu 5: Tại sao khi tạo vòng thi trên giao diện, tổng trọng số các tiêu chí bắt buộc phải bằng 100%?

Trả lời: Theo nguyên tắc của phương pháp Rubric-Based Learning (RBL), tổng trọng số đại diện cho 100% năng lực toàn diện của bài thi. Nếu tổng trọng số khác 100% (ví dụ chỉ 36%), công thức chuẩn hóa ma trận điểm sẽ bị sai lệch tỷ lệ. Giao diện Frontend tự động kiểm tra realtime và khóa nút lưu nếu chưa đủ 100% để bảo vệ tính toàn vẹn toán học của giải đấu ngay từ tầng client.